

Hacken Erlaubt!

Eine Praktische Einführung ins Ethical Hacking

Zürich Lernt, 20. September 2026

Antoine Neuenschwander

Dieses Handout dient als Referenz, alle Schritte werden gemeinsam durchgeführt.

Setup

1. Besuche die Website <https://htbzh.ch/>
2. Klicke auf *Onboarding*
3. Trage deine E-Mail Adresse ein erstes Mal ein und wähle Option **A** *Platform Invitation*
4. Du empfängst eine Einladung für die *Hack the Box* Plattform. Nehme die Einladung an und registriere ein Account
5. Geh zurück auf *Onboarding* (siehe Schritt 2)
6. Trage deine E-Mail Adresse erneut an, und wähle Option **B** *Meetup Lab Onboarding*

Ausgangslage

Die *VeloRapid Zürich GmbH* ist ein Velokurierdienst in Zürich. Ihre Website wurde 2019 von einem Freelancer aufgesetzt und seither nicht mehr angefasst. Sie haben nichts als eine IP-Adresse — nicht einmal eine URL.

Ihre Aufgabe: Finden Sie heraus, wie weit Sie kommen — und sammeln Sie unterwegs vier Flags im Format `HACKEN-ERLAUBT { . . . }`. Jedes Flag geben Sie auf der Flag-Seite ein.

Spielregeln

- Angriffe sind **ausschliesslich** gegen die oben genannte IP-Adresse im Rahmen des Workshops erlaubt. Alles andere ist nicht Teil der Übung und ausserhalb dieses Kurses strafbar (Art. 143bis StGB, unbefugtes Eindringen in ein Datenverarbeitungssystem).
- Mit Standard-Timings arbeiten. Leise ist besser: Wer laut scannt, fliegt auf.
- Die Firma, alle Personen und alle Daten in dieser Umgebung sind erfunden.

Wichtige Links

Onboarding (siehe Setup oben)	https://htbzh.ch
Hack The Box Plattform (Hacking Lab)	https://enterprise.hackthebox.com/
Flags einreichen	http://hacken-erlaubt.lab.htbzh.ch/
Zielsystem (IP Adresse)	139.59.135.155

Aufgabe 1 – Offene Türen finden

Ein Server kann auf 65535 Ports Dienste anbieten. Das Tool `nmap` probiert aus, welche davon antworten.

Welche Ports sind offen?

Standardmässig werden die 1000 häufigsten Ports/Dienste abgescannt:

```
nmap <ip-address>
```

Um alle 65535 Ports abzuscannen:

```
nmap -p- <ip-address>
```

Ein Dienst taucht erst jetzt auf. Welcher — und was heisst das für die Aussage «ich habe den Server gescannt»?

Was für Dienste antworten?

Das Tool `nc` baut eine “rohe” TCP Verbindung auf. Anhand der Server Antwort kann man u.U. feststellen was für Dienste betrieben werden:

```
nc <ip-address> <port>
```

Notieren Sie sich, was Sie finden:

IP Adresse	TCP Port	Dienst	Version
139.59.135.155			
139.59.135.155			
139.59.135.155			
139.59.135.155			
139.59.135.155			
139.59.135.155			
139.59.135.155			

Flag einreichen

Geben Sie die Flag ein im Format HACKEN-ERLAUBT { ... } ein: <http://hacken-erlaubt.lab.htbzh.ch/>

Aufgabe 2a — Umschauen

Einer der gefundenen Dienste ist eine Website. Rufen Sie sie im Browser auf (Achtung: `http://`, mit Portnummer). Was verrät sie über sich selbst, ohne dass man etwas «hacken» muss?

Sie könne auch das Tool `curl` verwenden, um die Website in der Konsole aufzurufen:

```
curl http://<ip-address>:<port>
```

Frage

Auf vielen Websites gibt es die Datei `robots.txt`. Die sagt Suchmaschinen, was sie *nicht* indexieren sollen. Schützt das etwas?

Aufgabe 2b — Verzeichnisse und Dateien finden

Nicht alles, was auf einem Webserver liegt, ist verlinkt. `gobuster` probiert Pfade aus einer Wortliste durch und zeigt, was tatsächlich existiert.

```
gobuster dir -u http://<ip-address>:<port> -w <wordlist.txt>
```

Was bedeuten die Statuscodes?

Code	Bedeutung
200	Ressource existiert und wird zurückgegeben
301 / 302	Weiterleitung auf eine andere Ressource
403	Existiert, aber Zugriff verweigert — trotzdem eine Information!
404	Nicht vorhanden

Ziel dieser Aufgabe

Finden Sie eine Datei mit Zugangsdaten und ein nicht verlinkter interner Bereich.

Hinweis

Anwendungen legen ihre Konfiguration oft in einer Datei ab, deren Name mit einem Punkt beginnt. Sie gehört nicht ins Webverzeichnis — liegt aber erstaunlich oft dort.

Verwenden Sie die Wörterliste unter

```
/usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
```

Flag einreichen

Geben Sie die Flag ein im Format `HACKEN-ERLAUBT { ... }` ein: <http://hacken-erlaubt.lab.htbzh.ch/>

Aufgabe 3 — Einloggen

Der interne Bereich ist über eine normale Anmeldemaske geschützt. Sie haben aus Aufgabe 2 alles, was Sie dafür brauchen.

Hinweis

Die Anmeldeseite sagt selbst, welches Konto sie verwendet. Lesen Sie den Hinweistext unter dem Formular.

Flag einreichen

Geben Sie die Flag ein im Format `HACKEN-ERLAUBT { ... }` ein: <http://hacken-erlaubt.lab.htbzh.ch/>

Frage

Wie viele Personendaten könnten Sie an dieser Stelle bereits abziehen? Was wäre das für die Firma — und für deren Kundschaft?

Aufgabe 4 — Passwörter knacken

In der Tabelle mitarbeiter stehen keine Passwörter, sondern **Hashes**: das Ergebnis einer Einwegfunktion. Man kann sie nicht «zurückrechnen» — aber man kann raten, hashen und vergleichen. Genau das macht das Tool `hashcat`.

Exportieren Sie die Hashes («Hashes exportieren») und knacken Sie sie:

```
hashcat -m 0 -a 0 --username velorapid_hashes.txt /usr/share/wordlists/rockyou.txt.gz
```

Ergebnisse nochmals anzeigen:

```
hashcat -m 0 --username -show velorapid_hashes.txt
```

Option	Bedeutung
<code>-m 0</code>	Hash-Typ: MD5
<code>-a 0</code>	Angriffsart: Wörterbuchangriff
<code>--username</code>	Die Datei hat das Format benutzername:hash

Flag einreichen

Geben Sie die Flag ein im Format `HACKEN-ERLAUBT { ... }` ein: <http://hacken-erlaubt.lab.htbzh.ch/>

Aufgabe 5 — Weiterkommen

Eines der geknackten Konten hat mehr Rechte als das Konto, mit dem Sie angemeldet sind. Melden Sie sich ab und mit diesem Konto neu an.

Zum Schluss: die Gegenseite

Notieren Sie sich während der Übung, an welchen sechs Stellen VeloRapid den Angriff hätte stoppen können. Wir vergleichen die Listen in der Schlussbesprechung.